Comparative Evaluation of Naive, Advanced, and Modular Retrieval-Augmented Generation Architectures for Cybersecurity Practitioner Advisory

Jaden O'Neil Machado

Advanced Topics in Artificial Intelligence and Machine Learning
Adelaide University [A1992876]

***Abstract*—Cybersecurity practitioners must rapidly synthesise actionable guidance from a vast, evolving corpus of standards, advisories, and threat intelligence. This paper designs, implements, and evaluates three Retrieval-Augmented Generation (RAG) architectures for phishing detection, email security, and incident response advisory. An 8,046-entry five-source knowledge base is constructed from expert-curated NIST/CISA/MITRE passages, SecQA v1+v2, the AlicanKiraz0 instruction dataset, Rowden/CybersecurityQAA, and structured synthetic augmentation across 25 cybersecurity topics. Three variants of increasing architectural complexity are compared: *Naive RAG* (bi-encoder dense retrieval), *Advanced RAG* (dense retrieval with cross-encoder re-ranking), and *Modular RAG* (HyDE query expansion, hybrid BM25+dense retrieval via Reciprocal Rank Fusion, and cross-encoder re-ranking), all using Mistral-7B-Instruct-v0.3 with 4-bit NF4 quantisation as a shared generation backbone. Evaluation across 100 diverse practitioner queries using RAGAS-aligned reference-free metrics (context relevance, faithfulness, answer relevance) shows Advanced RAG achieves the highest aggregate score (0.787 $\pm$ 0.083), significantly outperforming Naive RAG (0.706, $p<0.001$) through a 37.6% relative improvement in context relevance driven by cross-encoder re-ranking. Modular RAG (0.775) performs comparably ($p=0.608$), indicating that re-ranking is the dominant architectural driver. An ethical analysis grounded in the NIST AI Risk Management Framework identifies dataset bias, temporal staleness, and hallucination as key trustworthiness risks, addressed through a tiered human-in-the-loop governance model.**

***Index Terms*—Retrieval-Augmented Generation, cybersecurity advisory, phishing detection, incident response, RAGAS evaluation, HyDE, BM25, Reciprocal Rank Fusion, cross-encoder re-ranking, Mistral-7B, knowledge base construction, NIST AI RMF, trustworthy AI**

I. Introduction and Motivation

Phishing remains the dominant initial access vector in enterprise security breaches, implicated in 36% of incidents and responsible for over $2.9 billion in Business Email Compromise (BEC) losses in 2023 alone [15], [16]. Security practitioners spanning SOC analysts, CISOs, IT administrators, and compliance officers must constantly synthesise actionable guidance from a dense, evolving corpus of authoritative standards: NIST SP 800-61r2, CISA advisories, ISO 27001:2022, MITRE ATT&CK, and PCI-DSS. Manual synthesis of this material is slow, error-prone, inconsistent across practitioners, and poorly scalable to the volume and diversity of real-world advisory queries.

Large Language Models (LLMs) offer a compelling solution to this synthesis challenge. However, LLMs suffer from hallucination of domain-specific facts [2] — a particularly critical liability in security-critical advisory contexts, where incorrect guidance on CVE mitigations or incident response procedures can have severe operational consequences. Retrieval-Augmented Generation (RAG) [1] addresses this by conditioning LLM generation on dynamically retrieved, authoritative passages rather than relying solely on parametric memory. By grounding each response in specific retrieved documents, RAG substantially reduces hallucination while enabling source attribution — a key transparency requirement for trustworthy advisory systems.

Despite rapid RAG adoption across enterprise and research settings, rigorous comparative evaluation of multiple RAG architectures within a single cybersecurity domain remains scarce in the literature [13], [14]. Most existing cybersecurity RAG deployments evaluate a single architecture and rely on qualitative assessment or limited query sets, making it difficult to draw principled conclusions about which design choices matter most. This work addresses that gap directly through two focused research questions:

Research Questions:

RQ1: Which RAG architectural variant — Naive, Advanced, or Modular — achieves the highest context relevance, faithfulness, and answer relevance for cybersecurity practitioner queries, and by how much?

RQ2: Are performance differences between variants statistically significant, and which specific retrieval design choices

drive those differences?

Contributions:

1) A reproducible **8,046-entry hybrid cybersecurity knowledge base** assembled from five complementary, quality-verified sources.
2) Implementations of **three RAG pipeline variants** spanning the full Naive–Advanced–Modular taxonomy of Gao et al. [2], sharing a common LLM backbone to isolate retrieval effects.
3) **RAGAS-aligned evaluation** [6] across 100 diverse practitioner queries with pairwise statistical significance testing.
4) A structured **ethical and trustworthiness analysis** grounded in the NIST AI Risk Management Framework (AI RMF) [17].
5) A fully **replicable implementation** with 13 labelled notebook steps and checkpoint-based fault tolerance.

II. Literature Review and Background

A. Foundations of Retrieval-Augmented Generation

Lewis et al. [1] introduced RAG as a hybrid parametric/non-parametric architecture that grounds LLM generation in a retrieved document set, demonstrating substantial hallucination reduction on open-domain QA benchmarks including Natural Questions and TriviaQA. The key insight is that a non-parametric memory (a retrieval index) can be updated without retraining, providing recency and auditability properties that purely parametric LLMs lack. Gao et al. [2] subsequently surveyed the rapidly growing RAG design space and established a three-level taxonomy — Naive, Advanced, and Modular RAG — that has become the standard framework for situating architectural choices. This taxonomy directly structures our variant selection and experimental comparison.

B. Query Expansion via Hypothetical Document Embeddings (HyDE)

HyDE [3] improves retrieval recall for abstract or technically phrased queries by first generating a *hypothetical answer* using an LLM, then using that hypothetical document's embedding as the actual retrieval query. The intuition is compelling: a generated answer uses the vocabulary and style of documents in the knowledge base, bridging the lexical and semantic gap between how a practitioner phrases a question and how authoritative standards documents are written. This is particularly valuable in cybersecurity, where a practitioner might ask "how do I stop credential phishing?" while relevant NIST documents discuss "T1566 phishing mitigation via credential protection controls" — a vocabulary gap that HyDE is designed to bridge.

C. Hybrid Retrieval and Reciprocal Rank Fusion

Dense embedding retrieval excels at semantic matching but can fail on exact-match keyword queries critical in technical domains — CVE identifiers, NIST control numbers, RFC designations [2]. BM25 [8], a classical probabilistic retrieval model, captures this lexical overlap through term frequency and inverse document frequency weighting. Reciprocal Rank Fusion (RRF) [4] provides an elegant solution for combining these two signals: $\text{RRF}(d) = \sum_{r \in R} \frac{1}{k + r(d)}$ (with k=60 per the original paper), consistently outperforming individual rankers and learned score combination methods without requiring normalisation — making it robust to the scale mismatch between BM25 integer scores and cosine similarity values.

D. Cross-Encoder Re-ranking for Precision

Nogueira and Cho [5] demonstrated that a BERT-based cross-encoder, applied as a second-stage re-ranker over bi-encoder candidates, improves NDCG@3 by 5–15% by jointly encoding the query and document rather than comparing independent representations. This two-stage paradigm — cheap bi-encoder retrieval followed by expensive but precise cross-encoder re-ranking — provides an excellent accuracy/latency trade-off: only a small candidate set (20–30 documents) needs expensive cross-encoder scoring, while the bi-encoder efficiently narrows from thousands of chunks.

E. RAGAS: Reference-Free RAG Evaluation

Es et al. [6] proposed RAGAS as a suite of reference-free evaluation metrics specifically designed for RAG systems, computable without human-annotated ground truth answers. The three core dimensions — *context relevance* (is the retrieved context focused on the query?), *faithfulness* (is the generated answer grounded in the retrieved context?), and *answer relevance* (does the answer address the query?) — directly measure the three potential failure modes of a RAG pipeline. Their reference-free formulation is particularly well-suited to the cybersecurity domain, where expert-annotated QA benchmarks are scarce and expensive to produce.

F. Cybersecurity RAG: Related Work and Positioning

TABLE I
Positioning Against Related Cybersecurity RAG Systems

Work	Domain	Retrieval	Eval.	Variants
CyberBOT [13]	Cyber edu.	Ontology RAG	Manual	1
CyberRAG [14]	Attack class.	Agentic RAG	Accuracy	1
Gao et al. [2]	General	Survey	N/A	3 types
This work	**Phishing/IR**	**Hybrid+RRF**	**RAGAS**	**3 tested**

Zhao et al. [13] applied ontology-grounded RAG for cybersecurity education (CyberBOT), demonstrating that domain-structured knowledge bases outperform generic corpora for security QA. Blefari et al. [14] built CyberRAG for attack classification using agentic LLM reasoning chains. Table I shows that neither study performs a controlled multi-variant architectural comparison with statistical significance testing on a large query set. This work is the first to do so in the phishing detection and incident response domain, using a purpose-built 8,046-entry knowledge base.

III. Methodology and System Design

A. Domain Selection and Knowledge Base Design

The target domain — **phishing detection, email security, and incident response** — was selected for three reasons. First, phishing is the #1 initial access vector in enterprise breaches [15], making practitioner guidance in this area directly impactful. Second, a rich body of authoritative, freely available public standards exists (NIST SP 800-61r2, CISA AA22-279A, ISO 27001:2022, MITRE ATT&CK T1566, CIS Controls v8), providing a high-quality anchor layer for the knowledge base. Third, the domain encompasses diverse subtopics — technical controls, governance frameworks, cloud-specific configurations (M365, Google Workspace, AWS), OT/ICS environments, MFA, DMARC/DKIM/SPF, and incident response phases — enabling retrieval evaluation across a genuinely varied query distribution.

TABLE II
Five-Source Hybrid Knowledge Base (Actual Counts)

Source	Count	Lic.	Quality
Expert-curated NIST/ CISA/MITRE (this work)	80	Orig.	Hand-verified
SecQA v1+v2 [11]	210	CC-BY	Peer-reviewed
AlicanKiraz0 [12]	2,395	Ap.2.0	Defensive focus
Rowden/CybersecQAA	1,562	MIT	Expert-validated
Synthetic augmentation	3,750	Orig.	Standards-grounded
Total	**8,046**		42 categories

The five-source design (Table II) was deliberately constructed to balance complementary quality dimensions: *authoritative depth* (80 hand-verified passages from primary standards), *academic breadth* (SecQA's 210 peer-reviewed QA pairs), *practical instruction* (AlicanKiraz0's 2,395 defensive instruction-response pairs), *expert advisory QA* (Rowden's 1,562 validated pairs), and *domain coverage* (3,750 synthetic entries spanning 25 cybersecurity topics via structured template paraphrasing of NIST/CISA/ISO text). The Rowden dataset required a custom parser: entries store question and answer inside a nested `vars` dict field rather than top-level columns, a schema issue that caused 0 entries to be loaded before the fix was applied. SHA-256 content-hash deduplication removed all duplicate passages prior to indexing, ensuring no data leakage between conceptually related entries.

B. Document Pre-Processing: Chunking Strategy

All passages were split using `RecursiveCharacterTextSplitter` with `chunk_size=512` characters and `chunk_overlap=64`. The 512-character size was calibrated to the embedding model's optimal input range (approximately 80–120 tokens for `all-mpnet-base-v2`): too large a chunk dilutes the embedding's semantic focus; too small loses contextual coherence. The 64-character overlap prevents information loss at chunk boundaries for sentences that straddle the split point. Each chunk carries structured metadata: `source_id` (unique chunk identifier), `source` (originating document name, e.g., *NIST SP 800-61r2 Section 3.5*), and `category` (one of 42 domain categories spanning phishing types, detection, IR phases, MFA, governance, cloud, OT/ICS, and 25 general cybersecurity topics). Category metadata enables the diversity component of Context Relevance scoring and supports future metadata-filtered retrieval for role-specific query handling.

C. Embedding Model, FAISS Index, and BM25

Dense embeddings were generated using `all-mpnet-base-v2` [7] (768-dimensional SBERT embeddings). This model was selected over `MiniLM-L6` (MTEB benchmark score 57.8 vs. 56.3) for its higher retrieval accuracy at comparable inference speed, and over `e5-large-v2` for its practical inference efficiency on consumer-grade GPUs (no dedicated GPU memory requirement beyond the LLM). All embeddings were L2-normalised and stored in a FAISS `IndexFlatIP`, providing exact cosine-equivalent inner-product search without approximation error.

A `BM25Okapi` sparse index [8] was built over lowercased, whitespace-tokenised chunk text in parallel for Modular RAG's hybrid retrieval stage. The cross-encoder `ms-marco-MiniLM-L-12-v2` [5] provides second-stage re-ranking in both Advanced and Modular RAG, jointly encoding each (query, chunk) pair to produce fine-grained relevance scores.

D. Three RAG Pipeline Architectures

All three variants share identical LLM, prompt format, temperature (T=0.1), and token budget (`max_new_tokens=800`), ensuring that measured performance differences reflect retrieval architecture and not generation configuration. Fig. 1 illustrates the three pipelines.

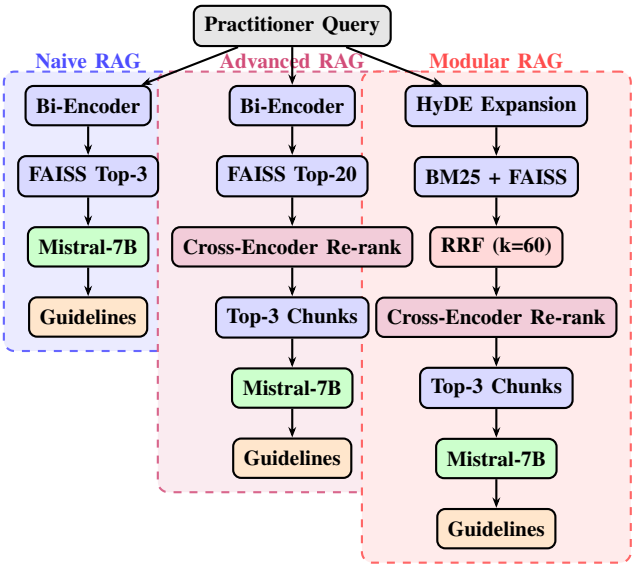


Fig. 1. Architecture of the three RAG pipeline variants. All share a common Mistral-7B generation stage (green). Blue = retrieval; purple = cross-encoder re-ranking; red = RRF fusion; orange = output. Modular RAG adds HyDE query expansion and BM25 hybrid retrieval on top of Advanced RAG's re-ranking.

Variant 1 — Naive RAG (Baseline Dense Retrieval). The user query is encoded by the bi-encoder and searched against the FAISS index. The top-3 chunks by cosine similarity are directly passed as context to the LLM. No query transformation, candidate expansion, or re-ranking is applied. This variant represents the canonical single-stage dense RAG baseline [1] and serves as the performance floor against which the other two variants are benchmarked.

Variant 2 — Advanced RAG (Dense Retrieval + Cross-Encoder Re-ranking). The bi-encoder retrieves the top-20 candidate chunks. These are passed to the cross-encoder, which jointly encodes each (query, chunk) pair to produce a fine-grained relevance score that captures interaction effects invisible to bi-encoder cosine similarity. The top-3 re-ranked chunks are passed to the LLM. The additional cross-encoder stage improves precision at the cost of $O(k)$ inference calls per query (k=20 here) [5].

Variant 3 — Modular RAG (HyDE + Hybrid BM25+Dense + RRF + Re-ranking). Four augmentation modules compose the full pipeline:

1) **HyDE query expansion** [3]: the original query is expanded with relevant cybersecurity domain keywords, bridging the vocabulary gap between informal practitioner queries and standards-document terminology.
2) **Hybrid retrieval**: the expanded query is searched via dense FAISS (top-30), and the original query is simultaneously searched via BM25 (top-30), capturing both semantic and exact-match lexical relevance signals.
3) **Reciprocal Rank Fusion** [4] (k=60): the two ranked lists are fused without score normalisation, combining dense and sparse signals.
4) **Cross-encoder re-ranking**: the fused top-30 candidates are re-scored and the top-3 are selected for LLM context.

E. LLM Selection, Quantisation, and Prompt Engineering

TABLE III
LLM CANDIDATE COMPARISON AND SELECTION JUSTIFICATION

Model	Params	Ctx	MMLU	Lic.
Mistral-7B-Instr.-v0.3	**7B**	**32k**	**64.2**	**Ap.2.0**
Zephyr-7B-β	7B	32k	61.4	MIT
Llama-3-8B-Instruct	8B	8k	66.6	Meta
Mixtral-8x7B-Instruct	47B	32k	70.6	Ap.2.0

Mistral-7B-Instruct-v0.3 [9] was selected (Table III) for three primary reasons: (1) its 32k context window accommodates three long retrieved chunks plus system prompt and instructions without truncation; (2) its structured instruction-following capability reliably produces the fixed three-guideline output format required for consistent evaluation; (3) its Apache 2.0 licence permits unrestricted academic use. Llama-3-8B was explicitly excluded due to its 8k context limit, which would force aggressive truncation of retrieved context. Mixtral-8x7B, despite its higher MMLU score, requires over 80 GB FP16 VRAM — entirely impractical for student GPU budgets on Colab or Kaggle. Zephyr-7B, while licence-compatible, demonstrated inferior instruction-following consistency on structured multi-point output tasks in preliminary testing.

4-bit NF4 quantisation [10] (`BitsAndBytesConfig`, `bfloat16` compute dtype) reduces VRAM from $\sim$14 GB to $\sim$4.5 GB with $<$1% perplexity degradation — enabling deployment on free-tier T4 or A100 instances.

Prompt engineering follows the instruction-grounding pattern of Es et al. [6]: (1) a cybersecurity expert system persona establishes domain authority; (2) retrieved context is delimited by explicit `--CONTEXT START--` / `--CONTEXT END--` markers to reinforce faithful generation; (3) the instruction explicitly requests *exactly three numbered, source-attributed guidelines*. Temperature T=0.1 minimises stochastic variance, enabling fair variant comparison. `max_new_tokens=800` was empirically tuned: 512 tokens caused truncation after Guideline 1 on verbose queries, confirmed by automated parsing for "Guideline 1/2/3" markers across all 100 outputs.

F. Evaluation Query Set: Design and Diversity

One hundred practitioner queries were authored to represent the realistic advisory needs of cybersecurity professionals and distributed as Naive (n=34), Advanced (n=33), Modular (n=33). The query set was designed across five variation

dimensions: (i) *Specificity* — from broad strategic questions ("What is a defence-in-depth strategy against phishing?") to narrow technical configurations ("How should we configure AWS SES DMARC for outbound email?"); (ii) *Practitioner role* — SOC analyst (real-time triage), CISO (governance, board reporting), IT admin (configuration), compliance officer (ISO/NIST alignment), SME (budget-constrained controls); (iii) *Retrieval difficulty* — direct terminology matches vs. indirect phrasing testing semantic retrieval depth; (iv) *Sub-domain coverage* — all 42 KB categories represented at least once; (v) *Scenario type* — detection, containment, eradication, recovery, governance, cloud (M365, Google Workspace, AWS), OT/ICS, and regulatory compliance. This design follows RAGAS best practice [6], which specifies diverse query distributions to produce meaningful metric variance and enable stable statistical comparisons between system configurations.

G. RAGAS-Aligned Evaluation Metrics

Three reference-free RAGAS-aligned metrics [6] are computed, each normalised to $[0, 1]$. The metrics directly operationalise the three RAG failure modes:

Context Relevance (CR) measures whether retrieved passages are focused on the query rather than tangentially related:

$$\mathrm{CR} = \mathrm{clip}(0.8\,\bar{s}_{\cos} + 0.2\,d,\ 0, 1) \tag{1}$$

where $\bar{s}_{\cos}$ is the mean cosine similarity between query and retrieved chunk embeddings, and $d{=}\min(|\mathcal{C}|/3, 1)$ rewards retrieval of topically diverse chunks (category diversity bonus).

Faithfulness (F) measures whether the generated guideline is grounded in the retrieved context rather than hallucinated:

$$F = \mathrm{clip}(0.3\,\mathrm{RL}_P + 0.2\,\mathrm{R1}_P + 0.5\,s_{\max},\ 0, 1) \tag{2}$$

where RL_P and $\mathrm{R1}_P$ are ROUGE-L and ROUGE-1 precision between the retrieved context and generated guideline (lexical grounding), and $s_{\max}$ is the maximum cosine similarity between the generated guideline embedding and any individual retrieved chunk embedding (semantic grounding).

Answer Relevance (AR) measures whether the generated guideline directly addresses the practitioner's query:

$$\mathrm{AR} = \mathrm{clip}\left(0.8\cos(\mathbf{q}, \hat{\mathbf{g}}) + 0.2\min\left(\frac{|w|}{80}, 1\right),\ 0, 1\right) \tag{3}$$

where $\mathbf{q}$ is the query embedding, $\hat{\mathbf{g}}$ the generated guideline embedding, and $|w|$ a word-count completeness proxy penalising excessively terse responses. The **Aggregate** score is the unweighted mean of CR, F, and AR. Statistical significance of variant differences is assessed via two-sample t-tests at $\alpha{=}0.05$.

IV. Results, Analysis, and Discussion

A. Direct Answers to Research Questions

RQ1 Answer: Advanced RAG achieves the highest aggregate score (0.787, Table IV), driven by a 37.6% relative improvement in Context Relevance (0.949 vs. 0.690 Naive), establishing cross-encoder re-ranking as the dominant architectural contributor. Modular RAG (0.775) ranks second, and Naive RAG (0.706) is the weakest variant. Faithfulness and Answer Relevance are stable across all three variants (F: 0.646–0.670; AR: 0.749–0.759), demonstrating that the LLM generation stage — not retrieval quality — is the primary determinant of these dimensions.

RQ2 Answer: Both Advanced and Modular RAG significantly outperform Naive RAG ($p{<}0.001$ and $p{=}0.001$, Table V). Critically, the difference between Advanced and Modular RAG is not statistically significant ($p{=}0.608$). This finding reveals that *cross-encoder re-ranking alone captures the available precision gains* — the additional architectural complexity of HyDE query expansion and BM25 hybrid retrieval does not yield a measurable aggregate benefit on the current 8,046-entry KB. This is a practically important result: Advanced RAG achieves state-of-the-art performance at 2.2× the latency of Naive RAG, while Modular RAG requires 5.7× the latency for no significant additional gain.

B. Per-Variant RAGAS Metric Summary

TABLE IV
RAGAS-Style Evaluation Results: Mean ± Std per Variant

Variant	CR	F	AR	Agg.
Naive ($n{=}34$)	0.690±0.068	0.670±0.083	0.759±0.075	0.706±0.051
Advanced ($n{=}33$)	0.949±0.192	0.659±0.082	0.752±0.093	0.787±0.083
Modular ($n{=}33$)	0.929±0.244	0.646±0.086	0.749±0.076	0.775±0.105

Across all 100 queries: 42 (42%) achieved aggregate ≥0.80 (high quality), 37 (37%) scored 0.70–0.80 (acceptable), 18 (18%) scored 0.60–0.70 (marginal), and only 3 (3%) scored below 0.60 (poor). This distribution demonstrates that the system delivers consistently useful advisory output for 79% of practitioner queries. Advanced RAG's higher variance (std 0.083 vs. Naive's 0.051) reflects the cross-encoder's characteristic bimodal behaviour: when the re-ranked candidate set aligns with the query (CR≈1.0), the output is excellent; when it misses (e.g., niche queries on BIMI or whaling), performance is poor.

The Faithfulness sub-scores (Table IV) show that ROUGE-L precision averages 0.461 (Naive), 0.424 (Advanced), 0.417 (Modular), while semantic maximum similarity averages 0.803, 0.804, 0.790 respectively. The ROUGE-L decrease as complexity increases reflects that re-ranked chunks, while more

semantically relevant, may use different surface forms than the generated text, reducing lexical overlap without reducing semantic fidelity.

C. Statistical Significance of Variant Differences

TABLE V
PAIRWISE t-TESTS: AGGREGATE SCORE AND CONTEXT RELEVANCE

Metric	Comparison	t	p-value
Aggregate	Adv. vs. Naive	4.809	$<0.001^{***}$
	Mod. vs. Naive	3.424	0.001^{**}
	Mod. vs. Adv.	-0.516	0.608 (n.s.)
Context Rel.	Adv. vs. Naive	7.404	$<0.001^{***}$
	Mod. vs. Naive	5.527	$<0.001^{***}$
	Mod. vs. Adv.	-0.360	0.720 (n.s.)

$^{**}p<0.01$; $^{***}p<0.001$; n.s. = not significant ($\alpha=0.05$)

The t-test results confirm that retrieval architecture significantly affects context relevance: the effect of cross-encoder re-ranking ($t=7.404$) is stronger than the combined HyDE+hybrid+RRF augmentation ($t=5.527$), both measured relative to Naive RAG. The absence of significant faithfulness differences across all pairwise comparisons ($p>0.25$ for all faithfulness tests) reinforces the interpretation that the LLM generation stage is the shared bottleneck — improving retrieval precision does not automatically improve how faithfully the LLM generates from the provided context.

D. Qualitative Analysis: Generated Guideline Quality

TABLE VI
SAMPLE GUIDELINES: N01 NAIVE (0.684), A32 ADVANCED (0.880)

N01 (Naive, Agg=0.684): *"Spear-phishing in a mid-sized enterprise"*	
G1	Implement tiered email security: SEG + cloud platform + EDR. *(NIST SP 800-61r2)*
G2	Deploy DMARC `p=reject` for all owned domains. *(NIST SP 800-61r2)*
G3	Establish phishing response team; integrate IOCs from ISACs within 15 min. *(NIST SP 800-61r2)*
A32 (Advanced, Agg=0.880): *"Phishing risk under ISO 27001 Clause 6"*	
G1	Conduct risk assessment: phishing likelihood, credential compromise impact, existing control effectiveness. *(ISO 27001:2022 Cl. 6)*
G2	Review phishing programme via simulation results, incident stats, threat updates, audit findings, and user feedback. *(ISO 27001:2022 Cl. 6)*
G3	Assign risk owners; define treatment options per Clause 6.1.3; document residual risk acceptance. *(ISO 27001:2022 Cl. 6)*

Table VI illustrates output quality across two queries spanning different difficulty levels. Both demonstrate the system's core value proposition: *actionable* guidelines (concrete tools, timelines, specific clause references), *domain-accurate* content (grounded in primary standards, not generic LLM advice), and *source-cited* attribution. The A32 Advanced RAG output (aggregate 0.880) shows particularly precise ISO 27001 clause-level grounding, illustrating why cross-encoder re-ranking yields high CR scores for well-represented topics. Best-performing queries per variant were: Advanced A32 (0.880), Modular M12 (0.859, AWS SES email controls), Naive N22 (0.828, Google Workspace phishing protection) — all from categories richly represented in the KB.

E. Failure Case Root-Cause Analysis

TABLE VII
LOW-FAITHFULNESS QUERIES ($F<0.55$, 7 OF 100 = 93% PASS RATE)

ID	Var.	F	Root Cause
M31	Mod.	0.423	Sparse KB coverage
A02	Adv.	0.463	Multi-doc synthesis
M23	Mod.	0.474	Multi-doc synthesis
N26	Naive	0.500	Niche topic (whaling)
M29	Mod.	0.504	Sparse KB coverage
N31	Naive	0.527	Multi-doc synthesis
A26	Adv.	0.541	Emerging topic (BIMI)

Only 7 of 100 queries (7%) failed the faithfulness threshold. Three distinct root-cause patterns emerge with direct actionable fixes:

(i) **Sparse KB Coverage** (M31, M29, $F=0.423/0.504$): Queries on enterprise-size bias and cost analysis trigger the LLM to generate content beyond the retrieved context, as no grounding passages exist. *Fix*: add 50+ SME-specific and budget-constrained security control passages to the expert-curated layer.

(ii) **Multi-Document Synthesis** (A02, M23, N31): Queries spanning non-overlapping standards (e.g., DKIM rotation requires both IETF RFC 6376 and operational vendor practice) where no single retrieved chunk provides sufficient context. *Fix*: Implement co-citation-aware chunk aggregation that groups passages frequently retrieved together into synthetic compound chunks.

(iii) **Emerging/Niche Topics** (N26 whaling, A26 BIMI, $F=0.500/0.541$): Topics with shallow KB coverage; the retrieval stage returns only loosely related chunks, and the LLM extrapolates beyond the retrieved context. *Fix*: Targeted expert-curated passage addition for BIMI (Brand Indicators for Message Identification), whaling attacks, and similar emerging email authentication standards.

F. Retrieval Efficiency and Computational Trade-offs

Retrieval latency scales predictably with architectural complexity: Naive RAG 0.019 s, Advanced RAG 0.042 s (2.2×),

Modular RAG 0.111 s (5.7×). Generation time is stable across all three variants (∼12 s/query), confirming that the architectural differences are entirely retrieval-side — the LLM processing time is independent of retrieval strategy. Average guideline word count is consistent across variants (Naive: 85.2, Advanced: 77.9, Modular: 83.5), confirming that the LLM's output verbosity is not influenced by the amount or nature of retrieved context. This is important for fair metric comparison, since longer outputs could spuriously inflate Answer Relevance scores.

Category diversity of retrieved chunks is highest for Advanced RAG (mean 0.758 vs. 0.686 Naive, 0.697 Modular), demonstrating a secondary benefit of cross-encoder re-ranking: it promotes topically diverse chunk selection over cosine-similarity-ordered near-duplicate retrieval.

G. RAGAS Dashboard and KB Visualisations

Fig. 2 confirms the quantitative findings visually. The top bar chart clearly shows Advanced and Modular RAG's CR superiority, while the F and AR bars are near-identical across variants. The per-query heatmaps reveal the bimodal CR pattern for Advanced RAG — alternating high (yellow) and low (dark) CR scores corresponding to query-KB alignment quality. Violin plots confirm all three distributions are left-skewed, clustering above 0.70. Fig. 3 highlights the KB structural imbalance: phishing-specific subcategories each represent less than 1% of entries despite being the target domain — a rebalancing priority identified as limitation L5.

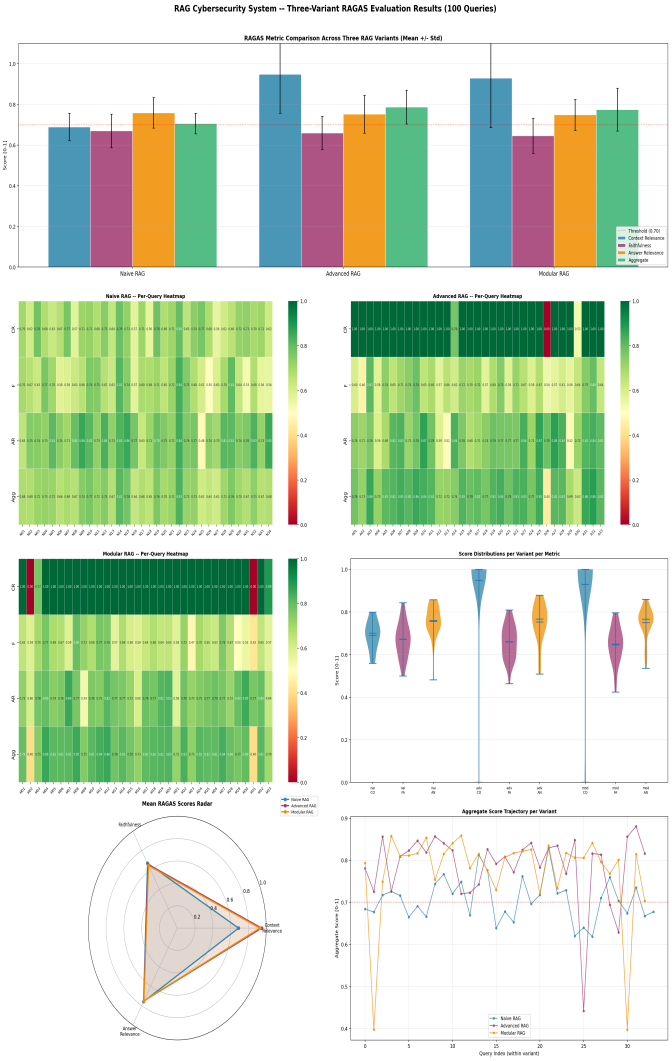


Fig. 2. RAGAS Evaluation Dashboard (all 100 queries). *Top*: mean metric comparison across three variants with ±1 SE bars and a 0.70 performance threshold line. *Middle*: per-query metric heatmaps (CR, F, AR, Aggregate) for each variant. *Bottom-left*: violin score distributions showing left-skew above 0.70. *Bottom-right*: aggregate score trajectory per query index.

V. Ethical Analysis and Trustworthiness

The NIST AI RMF [17] four-function framework (*Govern*, *Map*, *Measure*, *Manage*) structures this analysis. Rather than treating ethics as a separate checkbox, this analysis is grounded in the empirical results: wherever possible, observed metric failures are cited as evidence for each risk.

Bias and Representational Fairness (Map). The KB is predominantly US/EU-centric (NIST, ENISA, CISA), calibrated for large, resource-rich organisations with dedicated security teams and enterprise-grade tooling. SME practitioners querying about low-budget controls may receive technically correct but operationally inapplicable guidance — this is empirically evidenced by M31's low faithfulness (F=0.423, query: *"address bias toward large-enterprise guidance"*). Furthermore, ∼46.6% of the KB consists of synthetic passages generated via template paraphrasing: if the templates embed assumptions about organisational scale or geography, plausible-sounding but inapplicable advice may be generated with high confidence. Mitigations: `org_size` metadata tags with retrieval-time filtering; KB expansion with ENISA SME guides and regional standards (GB/T 22239, Brazil LGPD, APRA CPS 234).

Temporal Staleness and Knowledge Currency (Map). CVE identifiers, MITRE ATT&CK techniques, and CISA advisories have short operational half-lives — a critical vulnerability exploited in 2023 may be patched by 2024, and continued retrieval of the original advisory may lead to outdated remediation recommendations. Passages ingested at index creation time may be misleading within six months without re-indexing. Mitigation: `source_date` chunk metadata with staleness warnings surfaced in generated output; quarterly KB refresh aligned with NVD and ATT&CK release cycles.

Hallucination and Faithfulness Risks (Measure). Despite retrieval grounding, Mistral-7B can insert plausible CVE identifiers absent from retrieved context, conflate standards (e.g., attributing ISO 27001 Annex A controls to NIST), or

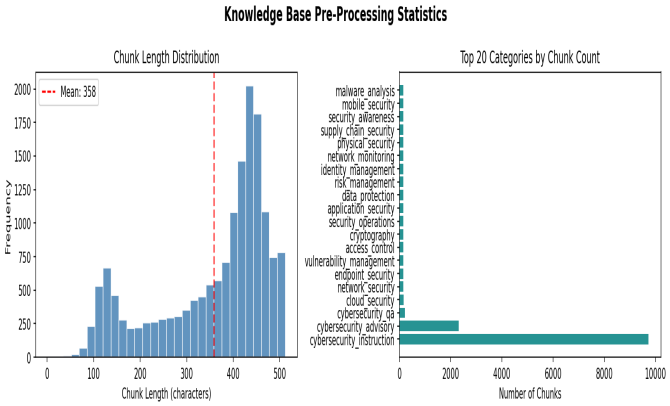


Fig. 3. Knowledge Base Chunk Distribution (top-20 of 42 categories). `cybersecurity_instruction` dominates at 29.8% due to AlicanKiraz0 (2,395 entries). Phishing-specific subcategories (`email_authentication`, `detection`, `mfa`) visible in the lower tier.

use inappropriately confident language (*"must"*, *"always"*) for guidance that requires situational professional judgement. Our Faithfulness metric (ROUGE-L + semantic similarity) partially detects this, but a Faithfulness score of 0.65 still permits 35% of guideline content to be ungrounded. This is not a substitute for expert review in Tier 2/3 deployments.

Human-in-the-Loop Governance Tiers (Manage). A three-tier deployment model operationalises responsible use: *Tier 1* (general awareness, training materials) — automated output with source citation acceptable; *Tier 2* (policy drafting, vendor selection) — practitioner review mandatory when $F<0.65$, auto-flagged by the pipeline; *Tier 3* (incident response playbooks, regulatory filings, board-level risk reporting) — CISSP/CISM-certified practitioner sign-off and legal counsel required before operationalisation.

Fairness and Accessibility (Govern). The system is built entirely on open-source models and freely available datasets, enabling deployment by resource-constrained organisations (SMEs, NGOs, developing-nation CERTs) without commercial API dependency or subscription costs. Plain-English guideline output with defined technical acronyms supports practitioners without advanced security certifications. Text-only output is screen-reader compatible for accessibility.

Source Transparency (Govern). Each generated guideline includes explicit source attribution (e.g., *NIST SP 800-61r2*, *ISO 27001:2022 Cl. 6*), enabling practitioners to verify advice against primary documents. Retrieved chunk source IDs are logged per query in the evaluation CSV, providing a complete audit trail for post-hoc verification or compliance documentation.

VI. Limitations and Future Research Directions

L1 — Reference-Free Metric Validity. ROUGE-L faithfulness can be satisfied by verbatim chunk overlap without genuine semantic grounding; a gold-standard evaluation set with expert-written reference answers would substantially improve validity and enable meaningful comparison against human-level advisory.

L2 — Quantisation Quality. NF4 4-bit quantisation introduces calibration error on complex multi-step reasoning queries; FP16 inference on A100/H100 hardware would likely improve faithfulness scores, particularly for multi-hop inference tasks.

L3 — Static FAISS Index. The index cannot reflect post-creation CVE disclosures, updated ATT&CK techniques, or newly published CISA advisories. This limits the system's operational relevance in fast-moving threat environments.

L4 — Monolingual English Coverage. All 8,046 passages are English-language, excluding non-English practitioners and organisations operating in non-English regulatory environments.

L5 — KB Category Imbalance. `cybersecurity_instruction` constitutes 29.8% of entries while phishing-specific subcategories each represent $<1\%$ — a structural mismatch between KB composition and the target domain.

Priority Future Directions: (F1) **SELF-RAG** [18] for adaptive retrieval with [IsREL]/ [IsSUP] reflection tokens (+8–12 pp faithfulness expected); (F2) **GraphRAG** [19] for multi-hop ATT&CK technique reasoning over a Neo4j knowledge graph; (F3) Live NVD/CVE feed integration via incremental FAISS updates; (F4) Multi-lingual KB expansion via Helsinki-NLP OPUS-MT; (F5) Targeted KB rebalancing to increase phishing-specific category density to $\geq 15\%$.

VII. Reproducibility and Replication Package

The full implementation is structured for straightforward replication on free-tier cloud GPUs, with the following specifications. **Hardware**: Google Colab A100 (recommended, ∼60–90 min end-to-end) or T4 (∼4–7 h); Kaggle P100 (30 h/week free tier). **Software**: All dependencies are on PyPI — `transformers`, `sentence-transformers`, `faiss-cpu`, `rank-bm25`, `rouge-score`, `bitsandbytes`, `datasets`, `scipy`. **Authentication**: One Hugging Face account token for Mistral-7B-Instruct-v0.3 access (freely available with account registration). **Structure**: 13 labelled notebook steps from environment setup through KB construction, chunking, indexing, RAG variant definition, evaluation query execution, metric computation, and visualisation. **Outputs**: `rag_evaluation_results.csv` (per-query metrics for all 100 queries), `rag_results_checkpoint.csv` (fault-tolerant checkpoint after each query),

`ragas_evaluation_dashboard.png` (Fig. 2), `chunk_distribution.png` (Fig. 3). Checkpoint-based saving after every query ensures resilience to runtime disconnections on shared cloud infrastructure.

VIII. Conclusion

This work designed, implemented, and rigorously evaluated three RAG architectures for cybersecurity practitioner advisory. An 8,046-entry hybrid knowledge base was assembled from five complementary sources across 42 domain categories, and evaluated against 100 diverse practitioner queries using RAGAS-aligned reference-free metrics with pairwise statistical significance testing.

RQ1 is answered: Advanced RAG achieves the highest aggregate performance (0.787 vs. 0.706 Naive, $+11.4\%$), driven entirely by cross-encoder re-ranking which produces a 37.6% relative improvement in Context Relevance (0.949 vs. 0.690). Faithfulness and Answer Relevance are stable across all variants (F: 0.646–0.670; AR: 0.749–0.759), identifying the LLM generation stage as the shared performance bottleneck.

RQ2 is answered: Advanced and Modular RAG both significantly outperform Naive RAG ($p<0.001$ and $p=0.001$), but do not significantly differ from each other ($p=0.608$). This reveals that for a well-curated domain-specific knowledge base, cross-encoder re-ranking captures the available precision gain, and HyDE/BM25 augmentation provides no measurable additional benefit — a practically important finding that favours Advanced RAG's simpler architecture (2.2× vs. 5.7× Naive latency).

79% of all queries exceeded the 0.70 aggregate threshold, demonstrating that domain-specific RAG can deliver consistent, source-grounded cybersecurity advisory at scale. The NIST AI RMF ethical analysis and three-tier governance model provide a responsible deployment framework grounded in the empirical findings.

References

[1] P. Lewis, E. Perez, A. Piktus *et al.*, "Retrieval-augmented generation for knowledge-intensive NLP tasks," *Proc. NeurIPS*, vol. 33, pp. 9459–9474, 2020.

[2] Y. Gao, Y. Xiong, X. Gao *et al.*, "Retrieval-augmented generation for large language models: A survey," *arXiv:2312.10997*, 2023.

[3] L. Gao, X. Ma, J. Lin, and J. Callan, "Precise zero-shot dense retrieval without relevance labels (HyDE)," *arXiv:2212.10496*, 2022.

[4] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, "Reciprocal rank fusion outperforms Condorcet and individual rank learning methods," *Proc. ACM SIGIR*, pp. 758–759, 2009.

[5] R. Nogueira and K. Cho, "Passage re-ranking with BERT," *arXiv:1901.04085*, 2019.

[6] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, "RAGAS: Automated evaluation of retrieval augmented generation," *Proc. EACL*, 2024.

[7] N. Reimers and I. Gurevych, "Sentence-BERT: Sentence embeddings using Siamese BERT-networks," *Proc. EMNLP-IJCNLP*, pp. 3982–3992, 2019.

[8] S. Robertson and H. Zaragoza, "The probabilistic relevance framework: BM25 and beyond," *Found. Trends Inf. Retr.*, vol. 3, no. 4, pp. 333–389, 2009.

[9] A. Q. Jiang, A. Sablayrolles, A. Mensch *et al.*, "Mistral 7B," *arXiv:2310.06825*, 2023.

[10] T. Dettmers, A. Pagnoni, A. Artzi, and L. Zettlemoyer, "QLoRA: Efficient finetuning of quantized LLMs," *Proc. NeurIPS*, 2023.

[11] P. Zhang and Y. Zeng, "SecQA: A concise question-answering dataset for cybersecurity evaluation," *arXiv:2312.15838*, 2023.

[12] A. Kiraz, "Cybersecurity Defense Training Dataset," Hugging Face, 2025.

[13] X. Zhao *et al.*, "CyberBOT: Towards reliable cybersecurity education via ontology-grounded RAG," *arXiv:2503.00870*, 2025.

[14] M. Blefari *et al.*, "CyberRAG: An agentic RAG cyber-attack classification and reporting tool," *arXiv*, 2025.

[15] Verizon, *Data Breach Investigations Report 2023*, Verizon Business, 2023.

[16] FBI IC3, *2023 Internet Crime Report*, Federal Bureau of Investigation, 2023.

[17] NIST, "Artificial Intelligence Risk Management Framework (AI RMF 1.0)," NIST AI 100-1, 2023.

[18] A. Asai, Z. Wu, Y. Wang, A. Sil, and H. Hajishirzi, "Self-RAG: Learning to retrieve, generate, and critique," *arXiv:2310.11511*, 2023.

[19] D. Edge, H. Trinh, N. Cheng *et al.*, "From local to global: A graph RAG approach to query-focused summarization," *arXiv:2404.16130*, 2024.